

Threat Intelligence & IOC

Progetto S9 L5



Gianluca Vitale

INDICE

#	SEZIONE	PAG.
1	sintesi	3
2	introduzione	3
3	Ambiente di Laboratorio	3
4	Procedura di Analisi	4
4.1	Trasferimento del file su Kali Linux	4
4.2	Vista generale del traffico	4
4.3	Identificazione del port scan	5
4.4	Porte aperte identificate	6
5	IOC Identificati	6
6	Ipotesi sul Vettore di Attacco	7
7	Conclusioni e Raccomandazioni	8

1. Sintesi

Il presente report documenta l'analisi di una cattura di rete fornita dal professore tramite un link Google Drive condiviso su Discord. Il file `Cattura_U3_W1_L5.pcapng` contiene 2083 pacchetti e l'obiettivo era identificare eventuali IOC presenti nel traffico, capire che tipo di attacco era in corso e proporre misure per limitarne i danni. L'analisi è stata condotta con Wireshark su Kali Linux applicando diversi filtri per isolare i pacchetti sospetti.

2. Introduzione

Durante la lezione teorica sono stati affrontati i concetti di Threat Intelligence e di IOC (Indicators of Compromise). La Threat Intelligence riguarda la raccolta e l'analisi di informazioni sulle minacce informatiche con lo scopo di anticipare e prevenire gli attacchi. Gli IOC invece sono evidenze osservabili nel traffico di rete o nei log di sistema che indicano che un attacco è in corso oppure che è già avvenuto.

Lo scopo di questo esercizio era applicare queste nozioni su una cattura reale, cercando di riconoscere pattern anomali nel traffico, identificare il tipo di attacco e proporre le azioni correttive più appropriate.

3. Ambiente di Laboratorio

Per questo esercizio è stata utilizzata una sola macchina virtuale, Kali Linux, in quanto non era necessario eseguire alcun attacco ma soltanto analizzare una cattura già esistente. Il file `.pcapng` è stato scaricato dal link condiviso dal professore su Discord e trasferito su Kali tramite cartella condivisa configurata su VirtualBox. Lo strumento di analisi utilizzato è Wireshark, già presente di default su Kali Linux.

Macchina utilizzata: Kali Linux (VirtualBox)

Tool di analisi: Wireshark

File analizzato: `Cattura_U3_W1_L5.pcapng` (2083 pacchetti totali)

IP attaccante nella cattura: 192.168.200.100

IP vittima nella cattura: 192.168.200.150 (METASPLOITABLE)

4.1 Trasferimento del file su Kali Linux

È stata creata una cartella chiamata Cartella_condivisa sul desktop del PC host e configurata come cartella condivisa nelle impostazioni di VirtualBox, con le opzioni Montaggio automatico e Rendi permanente abilitate. Da Kali è stato aperto il terminale e si è navigato fino alla cartella condivisa:

```
cd /media/sf_Cartella_condivisa  
ls
```

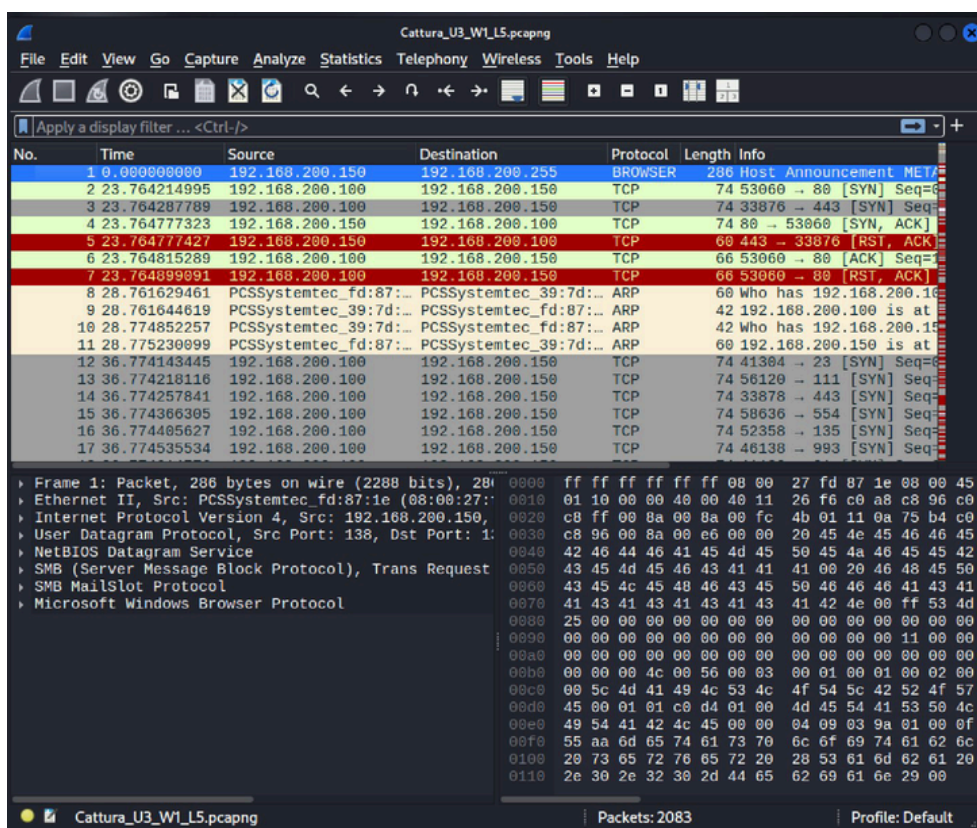
Una volta verificata la presenza del file, è stato spostato sul desktop e sono stati assegnati i permessi necessari per aprirlo:

```
mv Cattura_U3_W1_L5.pcapng /home/kali/Desktop/  
cd /home/kali/Desktop  
chmod ugo+rw Cattura_U3_W1_L5.pcapng  
chown kali Cattura_U3_W1_L5.pcapng
```

Dopo aver assegnato i permessi è stato sufficiente fare doppio clic sul file dal desktop per aprirlo direttamente con Wireshark.

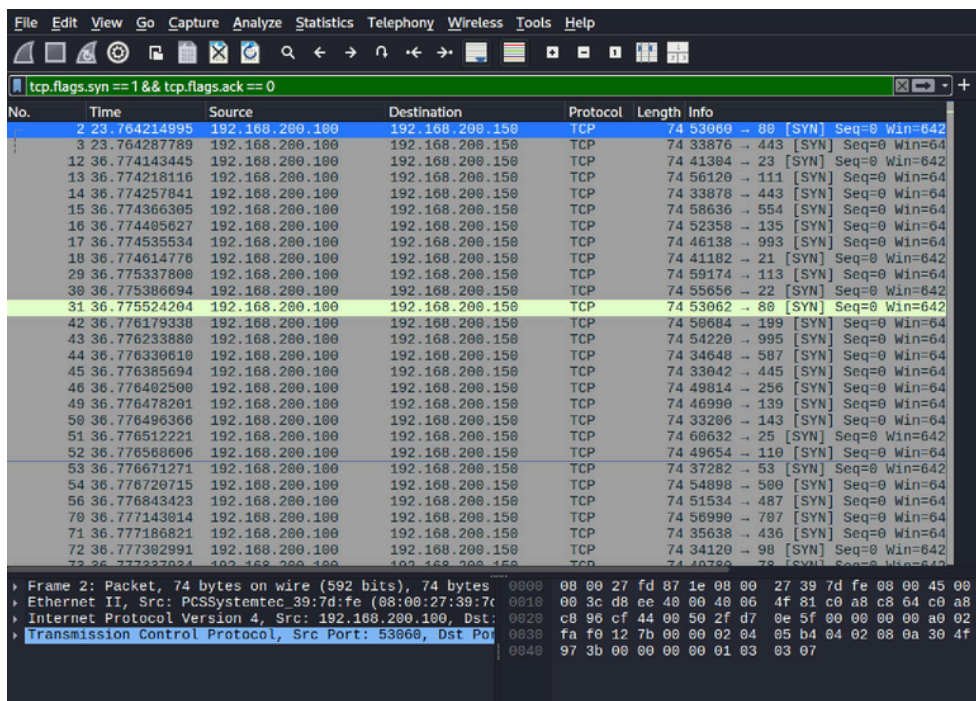
4.2 Vista generale del traffico

Aprendo la cattura in Wireshark si nota subito che quasi tutto il traffico è TCP tra due soli indirizzi: 192.168.200.100 e 192.168.200.150. Il primo pacchetto è di tipo BROWSER e nel suo contenuto si legge chiaramente la stringa METASPLOITABLE, che identifica il nome host della macchina vittima.



4.3 Identificazione del port scan

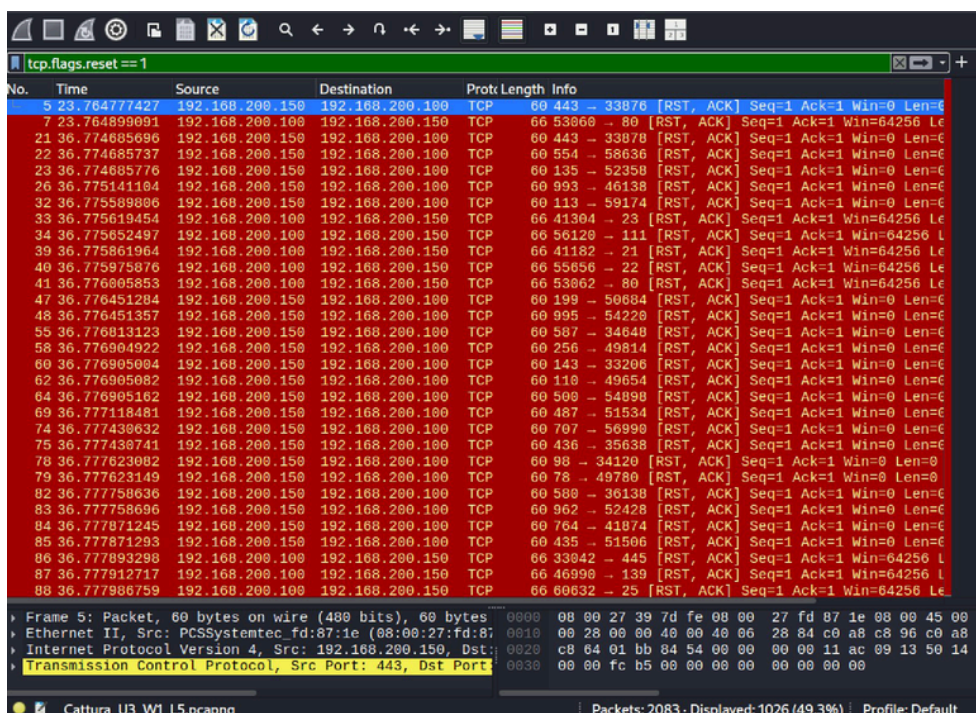
È stato applicato il filtro `tcp.flags.syn == 1 && tcp.flags.ack == 0` per isolare i soli pacchetti SYN puri, ovvero i tentativi di apertura di connessione. La barra del filtro è diventata verde confermando la correttezza della sintassi. Il risultato mostra che la macchina 192.168.200.100 stava inviando pacchetti SYN verso centinaia di porte diverse di 192.168.200.150 in modo rapido e sequenziale, senza mai completare il three-way handshake.



No.	Time	Source	Destination	Protocol	Length	Info
2	23.764214995	192.168.200.100	192.168.200.150	TCP	74	53060 → 80 [SYN] Seq=0 Win=642
3	23.764287789	192.168.200.100	192.168.200.150	TCP	74	53076 → 443 [SYN] Seq=0 Win=64
12	36.774143445	192.168.200.100	192.168.200.150	TCP	74	41384 → 23 [SYN] Seq=0 Win=642
13	36.774218116	192.168.200.100	192.168.200.150	TCP	74	56120 → 111 [SYN] Seq=0 Win=64
14	36.774257841	192.168.200.100	192.168.200.150	TCP	74	33878 → 443 [SYN] Seq=0 Win=64
15	36.774366305	192.168.200.100	192.168.200.150	TCP	74	58636 → 554 [SYN] Seq=0 Win=64
16	36.774405627	192.168.200.100	192.168.200.150	TCP	74	52358 → 135 [SYN] Seq=0 Win=64
17	36.774535534	192.168.200.100	192.168.200.150	TCP	74	46138 → 993 [SYN] Seq=0 Win=64
18	36.774614776	192.168.200.100	192.168.200.150	TCP	74	41182 → 21 [SYN] Seq=0 Win=642
29	36.775377809	192.168.200.100	192.168.200.150	TCP	74	59174 → 113 [SYN] Seq=0 Win=64
30	36.775386694	192.168.200.100	192.168.200.150	TCP	74	55656 → 22 [SYN] Seq=0 Win=642
31	36.775524264	192.168.200.100	192.168.200.150	TCP	74	53062 → 80 [SYN] Seq=0 Win=642
42	36.776179338	192.168.200.100	192.168.200.150	TCP	74	50684 → 199 [SYN] Seq=0 Win=64
43	36.776233880	192.168.200.100	192.168.200.150	TCP	74	54220 → 995 [SYN] Seq=0 Win=64
44	36.776330618	192.168.200.100	192.168.200.150	TCP	74	34648 → 587 [SYN] Seq=0 Win=64
45	36.776385694	192.168.200.100	192.168.200.150	TCP	74	33042 → 445 [SYN] Seq=0 Win=64
46	36.776402509	192.168.200.100	192.168.200.150	TCP	74	49814 → 256 [SYN] Seq=0 Win=64
49	36.776478291	192.168.200.100	192.168.200.150	TCP	74	46990 → 139 [SYN] Seq=0 Win=64
50	36.776496366	192.168.200.100	192.168.200.150	TCP	74	33296 → 143 [SYN] Seq=0 Win=64
51	36.776512221	192.168.200.100	192.168.200.150	TCP	74	68632 → 25 [SYN] Seq=0 Win=642
52	36.776569696	192.168.200.100	192.168.200.150	TCP	74	49654 → 110 [SYN] Seq=0 Win=64
53	36.776671271	192.168.200.100	192.168.200.150	TCP	74	37282 → 53 [SYN] Seq=0 Win=642
54	36.776729715	192.168.200.100	192.168.200.150	TCP	74	54898 → 580 [SYN] Seq=0 Win=64
56	36.776843423	192.168.200.100	192.168.200.150	TCP	74	51534 → 487 [SYN] Seq=0 Win=64
70	36.777143814	192.168.200.100	192.168.200.150	TCP	74	56990 → 787 [SYN] Seq=0 Win=64
71	36.777186821	192.168.200.100	192.168.200.150	TCP	74	35638 → 436 [SYN] Seq=0 Win=64
72	36.777302991	192.168.200.100	192.168.200.150	TCP	74	34120 → 98 [SYN] Seq=0 Win=642

Frame 2: Packet, 74 bytes on wire (592 bits), 74 bytes captured (592 bits) on interface 0
Ethernet II, Src: PCSSystemtec_39:7d:fe (08:00:27:39:7d:fe), Dst: 08:00:27:39:7d:fe
Internet Protocol Version 4, Src: 192.168.200.100, Dst: 192.168.200.150
Transmission Control Protocol, Src Port: 53060, Dst Port: 80, Seq=0, Win=642, Len=0

Con il filtro `tcp.flags.reset == 1` sono state visualizzate le risposte della macchina vittima. La quasi totalità delle porte ha risposto con RST, che indica porta chiusa. Wireshark evidenzia questi pacchetti in rosso. In totale ne risultano 1026, a conferma che la scansione ha coinvolto un numero molto elevato di porte.

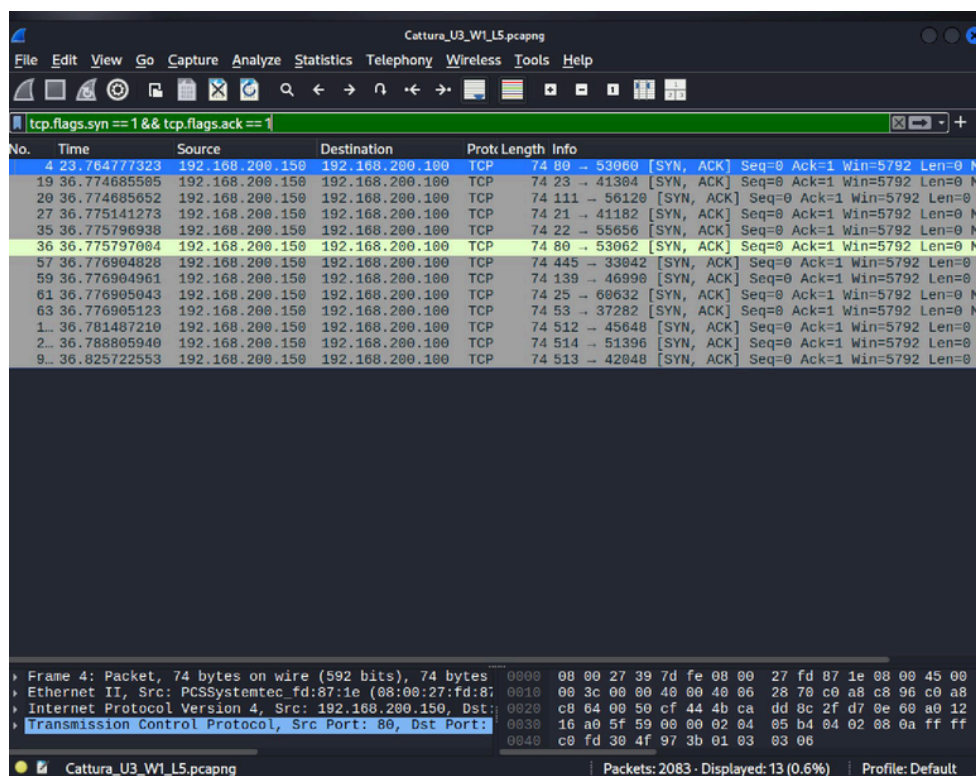


No.	Time	Source	Destination	Protocol	Length	Info
5	23.764777427	192.168.200.150	192.168.200.100	TCP	60	443 → 33876 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
7	23.764899091	192.168.200.150	192.168.200.100	TCP	60	53060 → 80 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
21	36.774685696	192.168.200.150	192.168.200.100	TCP	60	443 → 33878 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
22	36.774685737	192.168.200.150	192.168.200.100	TCP	60	554 → 58636 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
23	36.774685776	192.168.200.150	192.168.200.100	TCP	60	135 → 52358 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
26	36.775141184	192.168.200.150	192.168.200.100	TCP	60	993 → 46138 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
32	36.775589806	192.168.200.150	192.168.200.100	TCP	60	113 → 59174 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
33	36.775619454	192.168.200.150	192.168.200.100	TCP	60	41304 → 23 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
34	36.77562497	192.168.200.150	192.168.200.100	TCP	60	56120 → 111 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
39	36.775861964	192.168.200.150	192.168.200.100	TCP	60	41182 → 21 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
40	36.775975876	192.168.200.150	192.168.200.100	TCP	60	55656 → 22 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
41	36.776005853	192.168.200.150	192.168.200.100	TCP	60	53062 → 80 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
47	36.776451284	192.168.200.150	192.168.200.100	TCP	60	199 → 50684 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
48	36.776451357	192.168.200.150	192.168.200.100	TCP	60	995 → 54220 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
55	36.776813123	192.168.200.150	192.168.200.100	TCP	60	587 → 34648 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
58	36.776904922	192.168.200.150	192.168.200.100	TCP	60	256 → 49814 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
60	36.776905004	192.168.200.150	192.168.200.100	TCP	60	143 → 33206 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
62	36.776905082	192.168.200.150	192.168.200.100	TCP	60	110 → 49654 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
64	36.776905162	192.168.200.150	192.168.200.100	TCP	60	509 → 54898 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
69	36.77718481	192.168.200.150	192.168.200.100	TCP	60	487 → 51534 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
74	36.777430632	192.168.200.150	192.168.200.100	TCP	60	787 → 56990 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
75	36.777430741	192.168.200.150	192.168.200.100	TCP	60	436 → 35638 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
78	36.777523082	192.168.200.150	192.168.200.100	TCP	60	98 → 34120 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
79	36.777623149	192.168.200.150	192.168.200.100	TCP	60	78 → 49780 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
82	36.777758636	192.168.200.150	192.168.200.100	TCP	60	580 → 36138 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
83	36.777758696	192.168.200.150	192.168.200.100	TCP	60	962 → 52428 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
84	36.777871245	192.168.200.150	192.168.200.100	TCP	60	764 → 41874 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
85	36.777871293	192.168.200.150	192.168.200.100	TCP	60	435 → 51506 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
86	36.777893298	192.168.200.150	192.168.200.100	TCP	60	33842 → 445 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
87	36.777912717	192.168.200.150	192.168.200.100	TCP	60	46998 → 139 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
88	36.777986759	192.168.200.150	192.168.200.100	TCP	60	60632 → 25 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0

Frame 5: Packet, 60 bytes on wire (480 bits), 60 bytes captured (480 bits) on interface 0
Ethernet II, Src: PCSSystemtec_fd:87:1e (08:00:27:fd:87:1e), Dst: 08:00:27:fd:87:1e
Internet Protocol Version 4, Src: 192.168.200.150, Dst: 192.168.200.100
Transmission Control Protocol, Src Port: 443, Dst Port: 33876, Seq=1, Ack=1, Win=0, Len=0

4.4 Porte aperte identificate

Applicando il filtro `tcp.flags.syn == 1 && tcp.flags.ack == 1` sono stati isolati i pacchetti SYN-ACK, ovvero le risposte delle porte aperte. Su 2083 pacchetti totali solo 13 hanno risposto positivamente. Le porte aperte trovate sono: 21 (FTP), 22 (SSH), 23 (Telnet), 25 (SMTP), 53 (DNS), 80 (HTTP), 111 (RPC), 139 e 445 (SMB), 512, 513 e 514 (servizi Unix remoti).



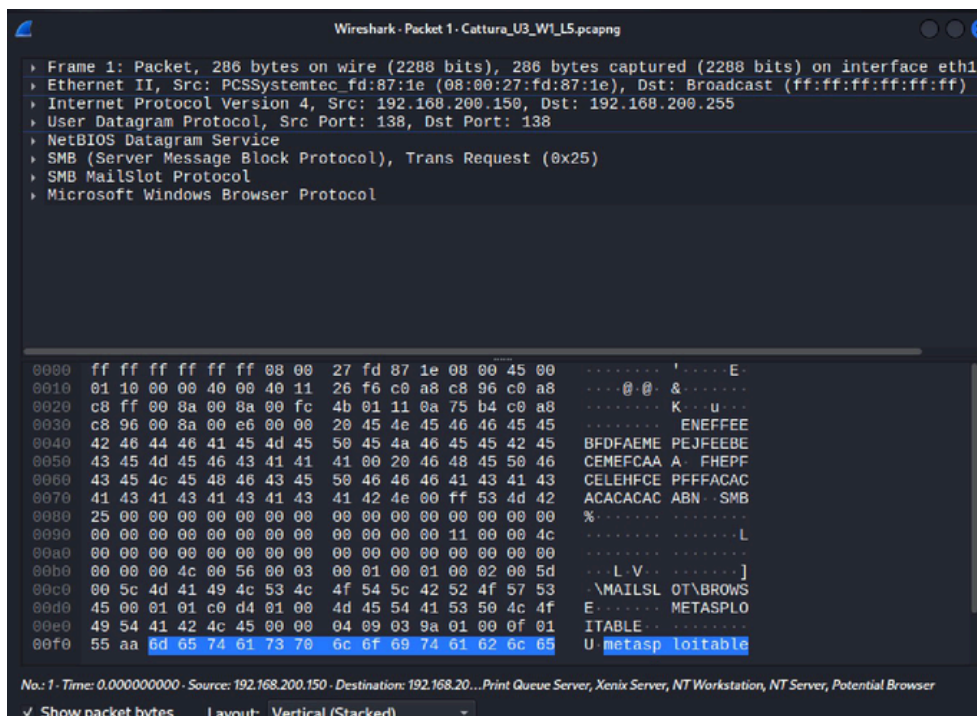
5. IOC Identificati

Dall'analisi della cattura sono stati identificati i seguenti Indicatori di Compromissione:

IOC 1 — Elevato numero di pacchetti SYN verso porte diverse in poco tempo. La macchina 192.168.200.100 ha inviato centinaia di SYN verso porte diverse su 192.168.200.150 in pochi secondi. Nel traffico normale questo comportamento non si verifica, ed è uno dei segnali più chiari di una scansione in corso.

IOC 2 — Pattern SYN/RST ripetuto su molte porte. Per ogni porta chiusa la vittima ha risposto con RST. La combinazione di tanti SYN seguiti da RST su porte sempre diverse è uno degli IOC più riconoscibili in presenza di un port scan.

IOC 3 — Nome host METASPLOITABLE visibile nel traffico. Nel primo pacchetto della cattura è visibile la stringa METASPLOITABLE nel payload. Questa informazione conferma all'attaccante che il target è una macchina vulnerabile e lo aiuta a pianificare i passi successivi.



IOC 4 — Servizi insicuri tra le porte aperte. Tra le porte aperte identificate figurano servizi noti per essere poco sicuri: Telnet (porta 23) e FTP (porta 21) trasmettono dati e credenziali in chiaro, mentre le porte 512, 513 e 514 corrispondono a servizi Unix remoti obsoleti e spesso privi di protezioni adeguate.

6. Ipotesi sul Vettore di Attacco

In base agli IOC identificati, il vettore di attacco rilevato è un port scan, ovvero una scansione sistematica delle porte della macchina target. Si tratta di una tecnica di ricognizione tipica delle fasi iniziali di un attacco, usata per scoprire quali servizi sono attivi prima di procedere con l'exploitation.

Il tipo specifico osservato nella cattura è un TCP SYN Scan: viene inviato un pacchetto SYN verso ogni porta e si aspetta la risposta. Se arriva SYN-ACK la porta è aperta, se arriva RST è chiusa. Non completando mai il three-way handshake, la scansione risulta più veloce e lascia meno tracce rispetto a una connessione completa.

Le informazioni raccolte, in particolare le porte aperte con servizi insicuri come Telnet e FTP, potrebbero essere usate in un secondo momento per tentare un accesso alla macchina, ad esempio tramite credenziali di default o vulnerabilità note su quei servizi.

7. Conclusioni e Raccomandazioni

L'analisi della cattura ha confermato la presenza di un port scan attivo sulla rete: la macchina 192.168.200.100 stava raccogliendo informazioni su 192.168.200.150 sondando sistematicamente le sue porte. Sebbene il port scan da solo non costituisca un attacco diretto, rappresenta una fase preparatoria da non sottovalutare perché precede quasi sempre qualcosa di più grave.

Per ridurre l'impatto e prevenire situazioni simili in futuro si dovrebbe:

Bloccare il traffico proveniente da 192.168.200.100 tramite una regola firewall, in modo da interrompere immediatamente la fase di ricognizione.

Disabilitare i servizi non necessari, in particolare Telnet (porta 23), FTP (porta 21) e i servizi Unix remoti (512, 513, 514), sostituendoli con alternative cifrate come SSH.

Configurare un sistema di rilevamento (IDS) in grado di identificare automaticamente pattern di port scan e generare alert in tempo reale.

Monitorare regolarmente i log di rete per individuare comportamenti anomali prima che evolvano in un attacco vero e proprio.